ZCAS UNIVERSITY

SCHOOL OF COMPUTING, TECHNOLOGY, AND APPLIED SCIENCES

CIT3311 - COMPUTER AND NETWORK SECURITY

END OF SEMESTER 1 EXAMINATION

4TH JUNE, 2026

14:00 HRS - 17:00HRS

TIME ALLOWED : WRITING – THREE HOURS

READING – 5 MINUTES

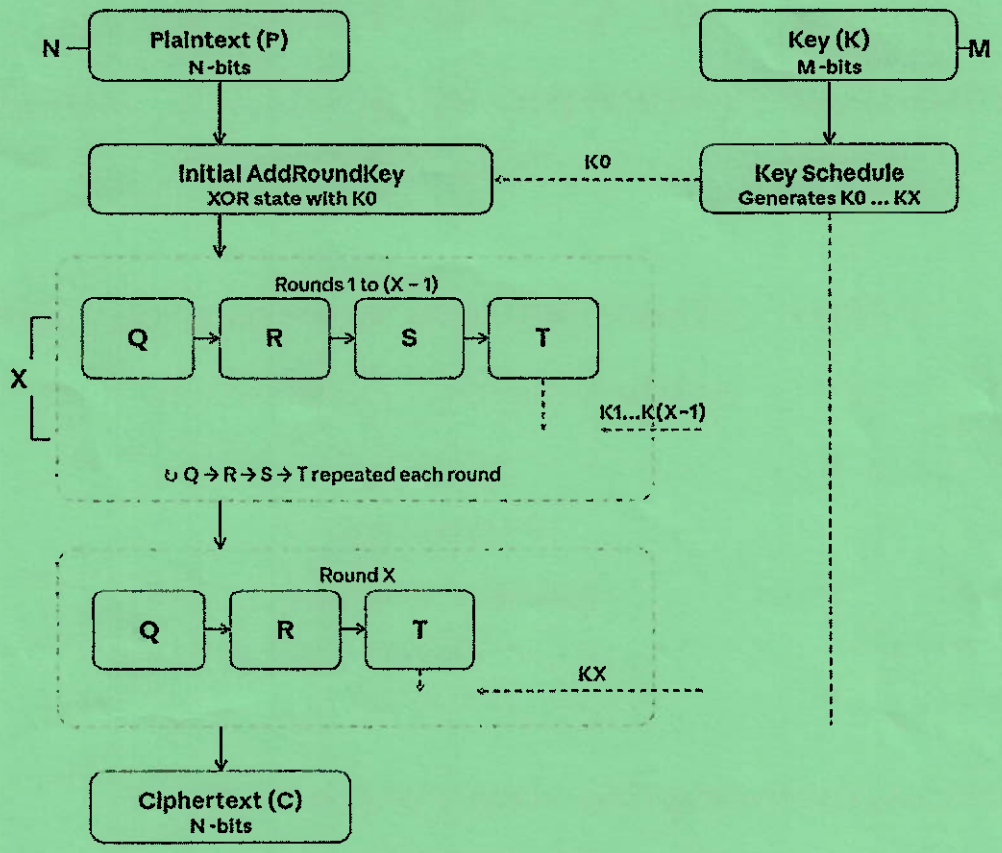
INSTRUCTIONS:

1. Section A: This section is **compulsory** and must be attempted.
2. Sections B: Answer **THREE (3)** questions from this section.
3. This examination paper carries a total of **100 marks.**
4. Candidates must **not turn this page** until the invigilator tells them to do so.

SECTION A: Question 1 is compulsory and must be attempted.

Question 1

AES is one of the most widely deployed symmetric encryption standards in modern computer and network security. The variant under consideration in this question is AES-256. Consider the AES-256 structure shown below and answer the questions that follow.



a) With reference to the figure above, identify and explain the components labelled M, N, Q, R, S, T, and X. For each label, state what it represents and its significance in the AES encryption process. **[14 Marks]**

b) Explain why the final round of AES omits one of the four cryptographic operations present in all preceding full rounds. In your answer, name the omitted operation and justify its exclusion from a mathematical and security standpoint. **[6 Marks]**

c) Given that $p = 7$ and $q = 11$, generate two RSA keys (Kp and Ks) representing the public and private keys respectively, where $e \neq d$. **[10 Marks]**

d) In a Diffie-Hellman key exchange, two parties agree on a prime p = 31 and a primitive root g = 7. Party A chooses a private key a = 9 and Party B chooses a private key b = 13. Compute the shared secret key. **[10 Marks]**

(Total: 40 marks)

SECTION B: Attempt any THREE questions. Each questions carries 20 marks.

Question 2

Information security is built upon a set of foundational concepts that guide how systems, data, and users are protected from both technical and human-based threats. A solid understanding of authentication, core security principles, risk terminology, and social engineering is essential for any security practitioner. The questions below assess your knowledge of these fundamental concepts.

(a) Name and explain the three factors of authentication, giving one practical example for each. In your answer, explain what multi-factor authentication (MFA) is and state one advantage it has over single-factor authentication. **[6 Marks]**

(b) Define each of the three principles of the CIA triad. For each principle, give one example of a scenario in which it is violated and state one technical control that can be implemented to enforce it. **[6 Marks]**

(c) Define the terms threat, vulnerability, and risk, and explain how the three are related to one another. Using a university computer lab as context, provide one example of each term and show how they combine to produce a specific risk. **[6 Marks]**

(d) Describe any two social engineering techniques used by attackers and state one organisational control that can reduce their effectiveness. **[2 Marks]**

(20 Marks)

Question 3

A university information system manages access to the following resources: Student Records, Exam Results, Finance Database, and Course Materials. The system has four users: Admin, Lecturer, Student, and Auditor. The permitted access operations are Read (R), Write (W), Execute (E), and Append (A). This is specified in a policy below:

- Admin has full access (R, W, E, A) to all resources
- Lecturer has Read and Write access to Course Materials, Read and Append access to Exam Results, and Read-only access to Student Records
- Student has Read-only access to Course Materials and Exam Results only
- Auditor has Read-only access to Student Records, Exam Results, and Finance Database, with no access to Course Materials

(a) Using the information above, construct a complete Access Control Matrix for the system by filling in the table below. **[16 Marks]**

Subject \ Object	Students Records	Exam Results	Finance Database	Course Material
Admin				
Lecturer				
Student				
Auditor				

(b) Explain two limitations of the Access Control Matrix model when applied to a large-scale system such as a national university network. **[4 Marks]**

(20 Marks)

Question 4

Wireless networks have become ubiquitous, but their open nature exposes them to a wide range of security threats. Over time, wireless encryption standards such as WEP, WPA, WPA2, and WPA3 have evolved to address increasing vulnerabilities. However, misconfigurations, weak authentication practices, and human factors continue to undermine WiFi security. A critical understanding of these protocols and practices is essential for designing and maintaining secure wireless environments.

a) In tabular form, compare WEP, WPA, WPA2, and WPA3 across the following dimensions: encryption algorithm, key length, authentication mechanism, and known vulnerabilities. From your table, explain why WPA3 is considered the most secure of the four standards. **[5 Marks]**

b) With reference to the WPA2 four-way handshake, explain how a KRACK (Key Reinstallation Attack) exploits the handshake process. Describe two countermeasures a network administrator can implement to mitigate this attack in a corporate wireless environment. **[5 Marks]**

c) A penetration tester conducts a wireless security audit on a company network and identifies the following: an evil twin access point, clients connecting over unencrypted HTTP, and WPS enabled on all access points. For each finding, explain the security risk it poses and recommend a specific technical countermeasure. **[5 Marks]**

d) Design a WiFi security policy for a small-to-medium enterprise (SME) covering the following four areas: access point configuration, user authentication, network segmentation, and incident response. For each area, state the policy requirement and justify it with reference to a specific wireless attack or threat. **[5 Marks]**

Question 4

A corporate network employs TLS 1.3 with OCSP stapling for web-facing services, IKEv2/IPSec with EAP-TLS for remote access, Kerberos with AES-256 encryption for internal authentication, and DNSSEC for name resolution integrity. A threat actor who has gained a foothold on an internal VLAN is observed performing the following: presenting a certificate that passes chain validation but fails OCSP revocation checks, exploiting an IKEv2 implementation that accepts CHILD_SA rekeying without re-authenticating the peer identity, replaying a Kerberos TGT whose kvno has not been incremented following a recent password reset, and injecting forged DS records into the DNS resolution path to redirect authentication traffic to a rogue KDC.

For each of the four observed actions, identify the exact protocol mechanism that has failed or been bypassed, demonstrate how each failure contributes to a progressive privilege escalation chain, specify the precise cryptographic primitive or protocol configuration that must be corrected to sever the chain at that point, and justify why the existing security controls failed to detect or prevent the attack. [20 Marks]

(20 Marks)

---------- **END OF EXAMINATION** ----------